

한전KPS(주) 상임감사

시 정 · 경 고 요 구

일련번호 2024-■□●♣, □★●●★⊗⊗△-9

제 목 해외현지조직 정보보안 관리 부적정

관계부서 ■□●♣

조치부서 ■□●♣, ⊗♣★◇★

내 용

1. 업무개요

회사는 「공공기관의 운영에 관한 법률」 제4조와 제5조에 따른 공공기관으로 국가정보원장이 정한 「국가 정보보안 기본지침」과 「산업통상자원부 정보보안 세부지침」을 준수하여야 한다.

또한, 회사는 「정보보안 업무처리기준」을 정하여, 국가안보와 국익에 관련된 정보, 정보통신망을 보호하기 위한 보안대책을 수립·시행하고 있다.

2. 비인가 저장매체 구매 및 사용 부적정

가. 판단기준

「정보화규정」 제23조 제3항에 따라 정보보안 업무에 대한 세부사항은 「정보보안 업무처리기준」에 따른다.

「정보화규정」 제24조 제3항과 「정보보안 업무처리기준」 제5조(정보보안담당관 운영) 제3항에 따라, 사업소별 정보보안담당관은 사업소장으로 하며, 사업소 정보보안담당자는 사업소 정보보안 담당부(팀)장으로 한다.

같은 기준 제6조 제4항에 따라 사업소 정보보안담당자는 소속직원의

보안대책 준수여부 감독, 비인가 단말기, 저장매체, 정보화기기 등 무단반입 여부 감독, 운영 정보시스템 및 저장매체의 자료유출에 대한 관리·감독 등에 대한 보안 활동을 수행하여야 한다.

같은 기준 제78조(휴대용 저장매체¹⁵⁾ 보안) 제4항에 따라 휴대용 저장매체를 비밀용·일반용으로 구분·관리하고 수량 및 보관 상태를 정기적으로 점검하며 외부 반출·입을 통제하여야 한다.

또한, 같은 기준 제78조 제8항에 따라 사업소 정보보안책임자는 소속 부서에 대하여 개별사용자의 휴대용 저장매체 무단 반출, 미등록 휴대용 저장매체 사용 여부 등 보안관리 실태를 정기적으로 점검하여야 한다.

나. 감사결과 확인된 문제점

그런데 감사대상기간 중 [가]는 2건의 휴대용 저장매체를 구매하면서 비밀용·일반용으로 구분·관리하고 수량 및 보관 상태를 정기적으로 점검하여야 함에도 별도의 휴대용 저장매체 관리대장과 점검대장을 미운영하였고, 자산 라벨 미부착, 반출입대장을 미관리하는 등 정보보안 업무 처리에 미흡하였다.

또한, 연도별 정보보안 자체감사 시, 아래 [표 1]과 같이 ‘해당없음’ 또는 ‘양호’ 표시하는 등 허위로 작성하여 보고하였다.

[표 1] 2022~2023년도 [가] 정보보안 자체감사 보고 내역

점검 연도	점검영역별	점검 결과	정보시스템		휴대용 저장매체 보안관리	사업소 정보보안 담당자	사업소 정보보안 실무자
	정보보안 기본활동		(휴대용) 일반 저장매체	(휴대용) PC정책 저장매체			
2022	양호	양호	(표시없음)	(표시없음)	4개 점검항목 ‘해당사항 없음’	♣♣♣	SYF
2023	양호	양호	(표시없음)	(표시없음)	4개 점검항목 ‘해당사항 없음’	☒♣☒	SYF

자료) [가] 소명 자료, 정보보안 자체감사 결과 제출([가]-1381(2022. 11. 11.), [가]-251(2023. 3. 1.)) 활용 재구성

15) 휴대용 저장매체: 「정보보안 업무처리기준」 제2조(정의)에 따라 디스켓·CD·외장형 하드디스크·USB메모리 등 정보를 저장할 수 있는 것으로 PC·서버 등의 정보시스템과 분리할 수 있는 기억장치

3. 국외 제공 상용 정보통신서비스 도메인 개설 및 사용 부적정

가. 판단기준

「정보보안 업무처리기준」 제66조(비공개 업무자료 처리) 제1항에 따라, 비공개 업무자료¹⁶⁾는 정해진 방법¹⁷⁾으로만 처리하여야 한다.

「정보보안 업무처리기준」 제66조 제1항의 정해진 방법 중 3호 가목에 따라, 비공개 자료는 회사 정보보안책임자가 자체적으로 구축·운용하는 전자우편시스템을 이용하여야 한다. 또한, 같은 조 제4항에 따라, 같은 조 제3항 제5호(민간 클라우드컴퓨팅서비스 기반의 영상회의 서비스 이용을 위한 일시적 저장·공유) 및 제6호(국민의 생명·신체, 국가안보 및 공공의 안전 등을 위하여 긴급히 작성, 저장, 수·발신이 필요하다고 회사 정보보안책임자가 인정하는 경우)에 해당하는 경우를 제외하고는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조 제1항 제2호에 따른 정보통신서비스(전자우편·메신저 등을 포함한다) 또는 국외에서 제공하는 이와 유사한 서비스를 이용하여 비공개 업무자료를 작성, 저장, 수·발신하여서는 안 된다.

나. 감사결과 확인된 문제점

그런데    는 회사 정보보안책임자가 자체적으로 구축·운용하는 전자우편시스템이 존재함에도 아래 [표 2]와 같이 2021년 9월 국외에서 제공하는 정보통신서비스 도메인을 생성하였다.

16) 비공개 업무자료: 비밀 및 대외비를 제외한 업무자료 중에서 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보, 또는 해당 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구에 해당하는 자료 또는 정보.

(  의 경우, 영업활동과 관련되어, 같은 법률 제9조 제1항 제5호 및 제7호인 1) 감사·감독·검사·시험·규제·입찰계약·기술 개발·인사관리에 관한 사항이나 의사결정 과정 또는 내부검토 과정에 있는 사항 등으로서 공개될 경우 업무의 공정한 수행이나 연구·개발에 현저한 지장을 초래한다고 인정할 만한 상당한 이유가 있는 정보, 2) 법인·단체 또는 개인의 경영상·영업상 비밀에 관한 사항으로서 공개될 경우 법인등의 정당한 이익을 현저히 해칠 우려가 있다고 인정되는 정보가 주로 해당)

17) 1. 회사 내부망 PC 및 서버에 작성 및 저장·보관, 2. 회사 정보보안책임자가 지급한 휴대용 저장매체에 작성 및 저장·보관, 3. 다음 각 목의 어느 하나에 해당하는 수단을 이용한 수·발신 또는 등재·열람(가. 회사 정보보안책임자가 자체적으로 구축·운용하는 전자우편시스템, 나. 국회사무처가 구축·운용하는 의정자료전자유통시스템 등 기관간 업무자료의 소통 또는 공동 활용을 위해 구축한 정보시스템), 4. 그 밖에 다른 법규에 따라 허용되는 처리방법

[표 2] ■■■●♂ 국외 정보통신서비스 도메인 개설 및 이용 내역

(단위 : INR)

도메인명	개설일자	사용 기간	개설비용
***	***	***	***

자료) ■■■●♂ 소명 자료 및 SAP 회계결의서 조회 자료 활용 재구성

또한, 「정보보안 업무처리기준」 제66조 제1항에 따라 비공개 업무자료를 정해진 방법으로 처리하여야 함에도 이외의 방법(국외에서 제공하는 정보통신서비스 도메인 개설)으로 처리하고자 하는 사안에 대해 본사 정보보안 주관부서와 별도의 협의를 한 사실은 확인되지 않았으며, ■■■●♂ 내부적으로 해당 정보통신서비스 도메인 개설에 관한 내부품의 작성이나 의사결정을 받은 내역을 확인할 수 없었다.

결과적으로, ■■■●♂는 아래 [표 3]과 같이 2021년 이후 총 11명의 사용자의 도메인을 생성하였고, 해당 상용 정보통신서비스를 이용하여 ■■■●♂ 영업 활동에 관한 자료, 회계, 세무, 계약 등 업무 전반 자료를 수·발신하고 있는 것을 확인하였다.

[표 3] ■■■●♂ 도메인 생성 및 운영 내역

구분	생성 연도	사용자	직위	도메인 주소
1	2021	***	***	***
2	2021	***	***	***
3	2021	***	***	***
4	2021	***	***	***
5	2021	***	***	***
6	2022	***	***	***
7	2022	***	***	***
8	2022	***	***	***
9	2022	***	***	***
10	2023	***	***	***
11	2023	***	***	***

자료) ■■■●♂ 소명 자료 재구성

따라서, 회사가 구축한 정보보안 시스템 이외의 방법으로 통제 불가능한 환경에서 업무를 수행하는 ■■■●♣의 정보보안 의식 부족과 이로 인한 회사의 비공개 자료가 유출되어 회사의 경영상·영업상 정당한 이익을 해칠 우려가 있다.

관계부서 의견 ■■■●♣는 정보보안 관리에 미흡한 점을 인정하고, 향후 유사사례 재발 방지를 위해 노력하겠다는 의견을 제시하였다.

조치할 사항

- ① b b 은 회사 정보보안 업무를 부적정하게 한 관련자에게 경고 조치하시기 바랍니다. (경고)
- ② ■■■●♣장은 회사 정보보안 업무를 부적정하게 한 관련자에게 주의 조치하시고, (주의)
- ③ ■■■●♣장은 개설된 도메인 사용을 중지하시고, 회사가 구축·운영하는 전자우편시스템을 이용하여 업무 처리하시고, 향후 유사사례가 발생하지 않도록 관련 직원들을 대상으로 교육을 시행하시기 바랍니다. (시정)
- ④ ☒☞★◇★장은 해외현지조직의 국외 정보통신망(상용메일) 사용 금지에 대해 강조하시고, 해외현지조직 정보보안 자체 점검을 강화하시기 바랍니다. (시정)

[관련자 명세]

소속	직위	성명	당시직무	해당 관리기간	귀책사유	조 치
❖❁▼☆☆●♣ (舊 ■■■●♣)	★☞☞	IBQ	☒@●장 겸무	2021. 1. 22. ~ 2024. 2. 16.	해외현지조직 정보보안 관리 부적정	경고
■■■●♣	↑↗	SYF	☒@●장	2022. 2. 16. ~ 현재	해외현지조직 정보보안 관리 부적정 No.010, 011, 012, 017	주의